



Cheat Sheet: подпись кода, «Publisher» и SmartScreen

AmneziaVPN Reconnect+Proxy · установщики AmneziaVPN_Reconnect_<версия>_windows_x64.{exe,msi} · 2026-09-24

1. Диагноз: почему «Unknown publisher»

Файл **подписан** (Authenticode, SHA-256, таймстемп Sectigo — настоящий), но сертификат **самоподписанный**:

```
Subject: CN=Juri Konoplev
Issuer:  CN=Juri Konoplev          ← Issuer = Subject
Valid:   2026-07-19 .. 2031-07-19
EKU:     Code Signing
Status:  A certificate chain processed, but
         terminated
         in a root certificate which is not
         trusted
```

Ни одно доверенное хранилище Windows (Root / Trusted Publishers) его не содержит — даже на машине сборки. Поэтому Windows показывает **Publisher: Unknown publisher**.

Две разные проверки — не путать:

1. **Authenticode** (диалог UAC / свойства файла → «Цифровые подписи»): валидна ли цепочка до доверенного корня. Лечится доверием к сертификату (вариант А) или СА-сертификатом (В).
2. **Microsoft Defender SmartScreen** («Windows protected your PC»): *репутация* файла и издателя в облаке Microsoft. Самоподписанный сертификат репутации не набирает **никогда**. Убирает только сертификат от СА + накопленные скачивания, либо EV / Azure Trusted Signing.

2. Проверить подпись любого файла

```
# PowerShell
$s = Get-AuthenticodeSignature 'C:\path\AmneziaVPN_Reconnect_5.0.1.1_windows_x64.exe'
$s.Status; $s.StatusMessage; $s.SignerCertificate.Subject; $s.SignerCertificate.Issuer
$s.TimeStamperCertificate.Subject

# signtool (из Windows SDK / VS Developer Prompt); /pa = политика Authenticode, /v = подробно
signtool verify /pa /v "C:\path\AmneziaVPN_Reconnect_5.0.1.1_windows_x64.exe"

# Что лежит в хранилищах
Get-ChildItem Cert:\LocalMachine\Root, Cert:\LocalMachine\TrustedPublisher | Where-Object Subject -like '*Juri Konoplev*'
```

Статусы: **Valid** — цепочка доверена; **UnknownError** + «terminated in a root certificate which is not trusted» — самоподписанный/недоверенный корень; **NotSigned** — подписи нет; **HashMismatch** — файл изменён после подписи.

3. Вариант А — доверить свой сертификат (бесплатно, только «свои» машины)

Публичную часть сертификата (.cer, без ключа) импортировать в **Trusted Root Certification Authorities** и **Trusted Publishers** на каждом ПК, где ставится программа. После этого Authenticode = **Valid**, в UAC и свойствах файла появляется «Publisher: Juri Konoplev». **SmartScreen на чужих ПК по-прежнему может ругаться** (репутации нет).

3.1 Экспорт .cer с машины сборки (один раз)

```
# из подписанного файла (ключ не нужен)
$c = (Get-AuthenticodeSignature 'D:\git\amnezia-client-reconnect\deploy\build\AmneziaVPN_Reconnect_5.0.1.1_windows_x64.exe').SignerCertificate
```

```
Export-Certificate -Cert $c -FilePath 'D:\git\amnezia-client-reconnect\deploy\certs\Juri_Konoplev_codesign.cer' # DER, публичная часть
# или из хранилища: Get-ChildItem Cert:\CurrentUser\My | Where-Object Subject -eq 'CN=Juri Konoplev' |
Export-Certificate -FilePath ...
```

3.2 Импорт на целевой машине (PowerShell от администратора)

```
Import-Certificate -FilePath .\Juri_Konoplev_codesign.cer -CertStoreLocation Cert:\LocalMachine\Root
Import-Certificate -FilePath .\Juri_Konoplev_codesign.cer -CertStoreLocation
Cert:\LocalMachine\TrustedPublisher
# то же через certutil:
certutil -addstore Root .\Juri_Konoplev_codesign.cer
certutil -addstore TrustedPublisher .\Juri_Konoplev_codesign.cer
# проверка:
(Get-AuthenticodeSignature .\AmneziaVPN_Reconnect_5.0.1.1_windows_x64.exe).Status # → Valid
```

GUI: двойной клик по .cer → «Установить сертификат» → «Локальный компьютер» → «Поместить все сертификаты в следующее хранилище» → «Доверенные корневые центры сертификации»; повторить для «Доверенные издатели». Удалить: `certutil -delstore Root "Juri Konoplev"`.

3.3 Что делает и чего не делает

	До (сейчас)	После импорта .cer
Свойства файла → Цифровые подписи	«Этот сертификат недействителен»	«Подпись действительна», Juri Konoplev
UAC (запуск от администратора)	жёлтый, Unknown publisher	синий, Publisher: Juri Konoplev
SmartScreen на этой машине	«Windows protected your PC»	может остаться — нажать «More info → Run anyway»
SmartScreen на чужой машине	«Windows protected your PC»	без изменений (нет репутации)

4. Вариант В — сертификат от публичного CA (убирает SmartScreen)

Вариант	Цена / год	Кому	Publisher	SmartScreen	Ключ
OV Code Signing (Sectigo, Certum, SSL.com, GlobalSign, DigiCert)	≈ \$70–300	физлицо (верификация паспорта + телефон) или организация	сразу	после набора репутации (недели / тысячи скачиваний)	с 06.2023 только аппаратный токен (FIPS 140-2 L2) / HSM / облако CA
Certum Open Source Code Signing	≈ €25–35 (+ карта/ридер один раз ≈ €50)	автор open-source проекта (форк GPL подходит)	сразу	как OV	карта Certum + SimplySign
EV Code Signing	≈ \$250–500	только организации (юрлицо, D-U-N-S)	сразу	сразу	токен / HSM
Azure Trusted Signing (Microsoft)	≈ \$10 / мес (Basic)	физлицо (история идентификации ≥ 3 лет) или организация; нужен Azure-аккаунт	сразу	сразу (корень Microsoft)	в облаке; подпись через signtool + dlib

4.1 Как переключить наш конвейер на новый сертификат

Подпись делают `cmake/sign_binaries.cmake` (все .exe/.dll перед упаковкой) и `cmake/sign_packages.cmake` (сам .exe/.msi), оба через `cmake/util/signtool.cmake`:

```
signtool sign /n "<SIGNT00L_SUBJECT_NAME>" /fd sha256 /td sha256 /tr http://timestamp.comodoca.com/?td=sha256 <файл>
```

- Сертификат должен лежать в **Cert:\CurrentUser\My** (для токена — его CSP/KSP сам подставит ключ). Тогда достаточно поменять `SIGNT00L_SUBJECT_NAME` в `pack_all.bat` на CN нового сертификата — и ничего больше.
- Если у CA другой таймстемп-сервер — заменить `/tr` (Sectigo/Comodo: `http://timestamp.sectigo.com`, DigiCert: `http://timestamp.digicert.com`, Certum: `http://time.certum.pl`).
- Azure Trusted Signing: `signtool sign /fd sha256 /tr http://timestamp.acs.microsoft.com /td sha256 /dlib "...\\Azure.CodeSigning.Dlib.dll" /dmdf metadata.json` — в `signtool.cmake` заменить `/n` на `/dlib ... /dmdf ...`.
- Токен на CI/фоновой сборке: PIN спрашивается интерактивно — либо подписывать на своей машине, либо облачный вариант (Trusted Signing / SimplySign).

5. SmartScreen: что нажимать и как копится репутация

- Синий экран: **More info** → **Run anyway**. Кнопка «Run anyway» видна только после «More info».
- Скачанный файл помечен «из интернета» (Zone.Identifier). Снять пометку: свойства файла → ☒ Unblock, или `Unblock-File .\\AmneziaVPN_Reconnect_5.0.1.1_windows_x64.exe`. Файл с витрины `https://10.0.0.222:9010` тоже помечается.
- Репутация копится **на сертификат** (OV/EV) и на конкретный хэш файла: каждая перепакровка = новый хэш = репутация с нуля, сертификатная — остаётся. Поэтому с CA-сертификатом выгодно реже перевыкладывать.
- Самоподписанный сертификат репутацию **не копит** — только хэш файла, и только пока файл не меняется.

- Отчёт «это безопасно» можно отправить: microsoft.com/wdsi/filesubmission (ускоряет, но не гарантирует).

6. Итог — что выбрать

Ситуация	Действие
Ставлю на свои 2–3 ПК	A : разложить <code>Juri_Konoplev_codesign.cer</code> рядом с установщиками, импортировать в Root + TrustedPublisher; на синем экране — Run anyway.
Раздаю коллегам в локалке	A + положить <code>.cer</code> и эту шпаргалку на витрину :9010; либо Certum OSS (дёшево, Publisher сразу).
Публичный релиз без предупреждений	Azure Trusted Signing (быстрее всего снимает SmartScreen) или EV (нужно юрлицо).

Ключ самоподписанного сертификата (в хранилище CurrentUser\My) и `deploy/certs/` в git не попадают (`.gitignore`); в репозиторий/на витрину кладётся только публичный `.cer`.